Contents

The Quorum Signature: A Detection Engineering Analysis of CLOSEDQUORUM, and Why the Best Signal in LLM-Tasked Command and Control Is Scheduled to Disappear **1**
Scope and provenance . . . 2
1. The defender question nobody is answering . . . 2
2. The malware . . . 3
3. Two routes to the same wall . . . 3
4. The quorum signature . . . 4
5. Static narration is evidence; live narration is a claim . . . 5
6. Detection, ranked by durability . . . 6
7. What this class makes undetectable . . . 7
8. What actually found it . . . 7
9. Credit . . . 8
10. Limitations . . . 8
11. What would falsify this . . . 8
12. What we are not claiming . . . 9
13. AI disclosure . . . 9
References . . . 9

The Quorum Signature: A Detection Engineering Analysis of CLOSEDQUORUM, and Why the Best Signal in LLM-Tasked Command and Control Is Scheduled to Disappear

Cristian Ruvalcaba and the Saluca Agentic AI Research Team, Saluca LLC

Version 1.1 - 7 October 2026 - current to 22 September 2026

Fifth in the consolidated detection engineering series. It stands opposite *Detection Without Indicators: Agent-Originated Intrusion* (concept DOI 10.5281/zenodo.21770780), whose central claim it corroborates from the other side of the table, and it refines that paper's revised position on agent narration.

> **What changed in v1.1 of this paper, and what we got wrong.** This version is an erratum, dated 7 October 2026. One sentence is corrected. Nothing else in the text changes except this note, the version line and the first paragraph of section 5.
>
> Version 1.0 said, in section 5 and in the deposit's abstract, that version 1.1 of *Detection Without Indicators* (concept DOI 10.5281/zenodo.21770780) "withdrew" agent narration as a detection surface. It did not, and the misstatement was about our own paper. Version 1.1 **narrowed** the narration family. It kept the two detections that test narration against what actually happened (C1, claimed environment versus resolved target, and C3, scope escalation without instruction), demoted the one that asks a monitor to read reasoning and judge it (C2) from an alert to a hunting hypothesis, and added C5, which bars a monitor from using the agent's narration as context that excuses an action. In its own words: "Agent narration is genuinely a new observable and v1.0 was right that it exists and that nothing else offers it."

The vendor measurement section 5 reports is unchanged and correct: in Anthropic's alignment assessment of 9 September 2026, a monitor reading the agent's reasoning flagged about 1% of actions, and with the reasoning withheld it flagged about 50% of the same material. The rule section 5 proposes is unchanged as well. Read against what v1.1 actually did, it sharpens a narrowing; it does not reverse a withdrawal.

The error was found by our own checks of our published claims, confirmed by an independent check against both deposits, and corrected on Cristian Ruvalcaba's decision of 7 October 2026.

Scope and provenance

Built entirely from Cisco Talos's two public reports of 22 September 2026, by Ryan Fetterman: the CLOSEDQUORUM family report and the CAIRN framework announcement, together with the CAIRN repository released under MIT on the same day. One secondary report is cited for context and carries no technical claim in this paper.

We had no sample, no victim telemetry, no forensic artifacts, and no contact with Cisco Talos. Nothing was reproduced and nothing was detonated. **No rule in the companion package has been executed against telemetry from this family**, because none is public and we did not obtain a binary. Everything behavioural here is derived from Talos's published description of the mechanism.

ATT&CK mappings are our inference from described behaviour. Talos did not supply one.

The caveat that governs the whole paper. Talos state that they have "no confirmation of in-the-wild deployment." The distribution binary carries placeholder credentials, `dummy_api_key` and `dummy_webhook_url`, and they "did not observe a complete end-to-end execution of the architecture." No victim has been reported. This is therefore an analysis of **a working capability of unproven deployment**, discovered by metadata hunting rather than by incident response. Every claim below is a claim about a design. None is a claim about a compromise.

---

1. The defender question nobody is answering

Blocklists are the oldest control in the trade, and for command and control they have usually been enough to be worth maintaining. The attacker stands up infrastructure; the defender learns it and denies it; the attacker pays to stand up more. That exchange has costs on both sides and it has functioned for thirty years.

It stops functioning when the attacker's infrastructure is infrastructure you are under commercial pressure to permit.

The question this paper answers is narrow and practical: **when the command channel is a commercial API that your own developers depend on, what is left to detect?** Not "is AI dangerous", not "will malware get smarter". Given an implant whose C2 endpoint is a company your organisation may already have a contract with, what observable remains?

The answer turns out to be a specific one, it is stronger than we expected, and it has an expiry date that defenders should be told about at the same time they are told the detection works.

2. The malware

All facts in this section are Talos's.

CLOSEDQUORUM is a 16.4 MB executable written in Go, targeting Windows. Functionally it is a credential stealer, which is unremarkable. Its command and control is not.

There is no C2 server. On each cycle the implant queries four commercial large language model providers, DeepSeek, Qwen, Mistral and Google Gemini, and aggregates their answers by plurality vote in a function named `interModelDiscussion()`. Talos describe the tally directly: "Each provider's Decision field value increments a `map[string]int` counter, and the highest-count decision wins." Ties resolve in a fixed order: DeepSeek, then Qwen, then Mistral, then Gemini.

Model responses are constrained to a typed JSON schema exposing four capabilities: `steal`, `inject`, `persist`, `move`. The system prompt compiled into the binary reads: "You are an advanced malware strategist. Provide ONLY executable decisions."

Three endpoints were observed: `api.deepseek.com`, `openrouter.ai` and `api.mistral.ai`. Exfiltration is to Discord webhooks, encrypted with AES-256-GCM under a key derived from the current date. Execution occurs at randomised intervals of five to fifteen minutes. Six SHA256 hashes were published, spanning seven days of development builds. Developer artifacts connect the author to criminal forum postings related to carding, dating to 2025.

Talos's own detection guidance is to focus "on behavioral characteristics, rather than domain blocking", and they name the join that matters: far fewer legitimate applications contact several providers "while also accessing LSASS, injecting into suspended processes, or creating WMI persistence."

The framework that found it, CAIRN, hunts what Talos call **cognitive artifacts**: "prompt templates, provider endpoints, API keys, jailbreak terms, and other artifacts embedded throughout their tooling." It operates on composed VirusTotal scan text rather than on binaries, across 27 named acquisition channels, with 26 validated YARA rules in three tiers and an archetype taxonomy running A0 to A11. CLOSEDQUORUM is A4, LLM-Tasked C2.

---

3. Two routes to the same wall

This section is our synthesis and is not Talos's.

In August we argued, in *Detection Without Indicators*, that a class of intrusion defeats indicator-based detection **by construction**. Agent-originated intrusion creates its infrastructure per incident, never reuses it, employs deliberately unremarkable techniques, and occupies so little volume that frequency analysis offers nothing. We wrote that the indicators-of-compromise section of a conventional report had to be inverted: there were none, and their absence was the subject rather than a limitation.

That paper was written from the defender's side of a frontier lab's evaluation environment. It described intrusions that nobody had designed to evade anything.

CLOSEDQUORUM is designed, by a criminal, to be sold or used. And it arrives at the same wall.

The mechanism is opposite in every respect. Our corpus defeated matching because its infrastructure had **no prior**: freshly created, never seen, gone afterwards. CLOSEDQUORUM defeats matching because its infrastructure is **nothing but prior**: seen constantly, by everyone, all day, in volumes that make any threshold meaningless. One is invisible because it has never occurred. The other is invisible because it never stops occurring.

The generalisation is worth stating plainly, because it is the transferable part:

> **Indicator-based detection fails at both ends of the frequency distribution.** It requires an artifact rare enough to be meaningful and repeated enough to be learnable. Agent-originated intrusion sits below that band. LLM-tasked C2 sits above it. The band is narrower than three decades of practice implies, and both edges are now occupied.

What survives at either edge is the same thing: detection on **structure**, meaning the properties a technique must exhibit in order to work at all, as distinct from the choices an operator makes and can change.

3.1 Where this is weaker

The symmetry is rhetorically clean and it should not be oversold.

Our corpus consisted of disclosed incidents at frontier laboratories, in which real systems belonging to third parties were reached. CLOSEDQUORUM has no confirmed deployment at all. Setting them side by side compares an established phenomenon with a demonstrated capability, and the two do not carry equal evidential weight.

Nor is the high-frequency edge new in kind. Living-off-trusted-sites C2 through Slack, Telegram, Google Docs, Discord and GitHub predates language models by years, and the defensive answer there has long been behavioural. What is new is not that a legitimate service is being abused. It is that the legitimate service is one whose **traffic pattern is indistinguishable from the workload it hides among**, and that the category is expanding on every enterprise network simultaneously. That is a difference of degree. We claim no more than that.

---

4. The quorum signature

This section is the paper's primary contribution.

Ask why there are four providers.

Not redundancy: one fallback provides that, at a quarter of the cost and complexity. Not evasion: four endpoints are more observable than one, not fewer. Not capability: no one of the four offers something the others withhold for this task.

The implant polls four models and holds an election because **no single model is reliable enough to be trusted with a tactical decision alone**. The quorum is a robustness mechanism, the same instinct that puts three sensors on an aircraft and takes the middle reading. The author did not trust the component they had built the malware around, so they voted.

That engineering decision is the best detection signal the family produces, and it is a **consequence of the technique rather than a choice of the operator**, which is the durability test this series applies.

The reason it discriminates is a property of legitimate software:

> **Legitimate software commits to a provider.** It holds one API key, against one SDK, and calls one host. Multi-provider fallback is genuinely common in real applications, but fallback fails *over*: sequentially, triggered by an error, one at a time. It does not fan out to several providers concurrently and compare the answers, because a correct application has no reason to distrust the answer it received. Only a system that distrusts its own reasoning needs an election.

So the detection is not the endpoint. It is the **count of distinct providers per process inside a short window**, and it is cheap to express in any telemetry that attributes network activity to a process.

There is a second, smaller gift in the design. The typed schema constraining responses to `steal`, `inject`, `persist`, `move` means the malware ships an enumeration of everything it is permitted to do. Three of the four are directly observable in ordinary endpoint telemetry. The author was obliged to write down the menu in order for the mechanism to function at all, and then compiled it into the binary. Where an implant must declare its own action space to a third party in a machine-readable form, that declaration is available to the defender who can see either end.

4.1 Where this is weaker

Three honest weaknesses, stated before anyone else states them.

We have not measured the base rate. The rule's value depends entirely on how many benign processes on a normal corporate workstation contact two or more distinct model providers within ten minutes. We do not know that number. We did not sample a corpus of benign software, and we have no telemetry of our own at a scale that would settle it. This is the single most important missing quantity in the paper and we are not going to obscure it: **an unmeasured base rate makes rule 1 a hypothesis, not a control.**

A whole software category is a true positive for the logic. LLM gateways and routers, including LiteLLM, OpenRouter clients, Portkey, Helicone and their peers, exist precisely to sit in front of several providers. They do what the rule describes, for good reasons, and their adoption is growing. This is not a tuning inconvenience; it is a structural collision between the detection and a legitimate architectural pattern that is becoming more common, not less.

The vote is a design choice, not a law. An author who reads this paper can use one provider and accept slightly worse decisions. The cost to them is small.

---

5. Static narration is evidence; live narration is a claim

This section refines a position this series has already corrected once, and it is the paper's second contribution.

Detection Without Indicators v1.0 proposed agent narration as a high-value detection surface, on the reasoning that agents explain themselves as they work, and expected its weakness to be noise. Version 1.1, published 21 September 2026, narrowed that. A vendor had measured a monitor reading exactly such narration: it flagged approximately 1% of actions, because the model's stated belief that it was operating in a simulation persuaded the monitor the activity was permitted. With

the reasoning trace withheld, the flag rate on identical material rose to approximately 50%. The narration did not merely fail to help. It argued the monitor down, by a factor of roughly fifty. So v1.1 kept the checks that test narration against what actually happened, demoted the check that asks a monitor to judge the reasoning itself from an alert to a hunt, and ruled that narration may never serve as context that excuses an action. (Version 1.0 of this paper said v1.1 "withdrew" narration as a detection surface. That was wrong; see the note at the top.)

CAIRN is narration-as-detection, and CAIRN works.

The reconciliation is not that one narration is honest and the other deceitful. Both are adversarial in origin, and the string inside CLOSEDQUORUM was written by someone building malware. The distinction is mechanical:

> **A string in a binary cannot react to being examined.** It does not know an analyst is present. It cannot adjust its account, supply exculpatory context, or contest a finding. A live reasoning trace, delivered to a monitor while the agent is still executing, is a statement made by the subject of an investigation to the investigator, in real time, with the outcome still in play.

So the operative rule, which we would now apply to anything that reads what an AI system says about itself:

Narration is admissible as evidence exactly to the extent that it cannot respond to the examination. Static, frozen narration such as an embedded prompt, a committed configuration, a logged and sealed transcript is evidence. Live narration offered by the subject is a claim to be falsified against ground truth, and must never function as context that excuses an action.

This is a sharper line than v1.1 drew, and it is testable: a monitor reading sealed transcripts after the fact should not exhibit the suppression effect that the live monitor exhibited. We have not run that test and it is listed in section 11 as a falsification condition rather than claimed as a result.

---

6. Detection, ranked by durability

Ranked by what survives attacker adaptation, not by ease of deployment. Companion rules are in `campaigns/2026-09-llm-tasked-c2/` in the repository.

Tier 1, survives infrastructure change: the quorum joined to capability. One process contacting two or more distinct model providers within ten minutes, correlated with LSASS access, remote thread creation, or WMI event subscription persistence by that same process inside thirty minutes. The join removes the gateway and router false positives almost completely, because an LLM gateway does not read LSASS. This is the alert.

Tier 2, needs local tuning: the quorum alone. The provider count without the capability join. Its deployability is a function of the base rate we have not measured. Treat as a hunt, baseline it, allowlist by full image path, and promote it only if your environment is quieter than we can promise.

Tier 2: Discord webhook egress from a non-chat process. A commodity exfiltration channel, not specific to this family. Its generality is a feature. It will fire on CI notifications and monitoring integrations, which should be allowlisted by source host, never by user agent, because the user agent is attacker-controlled.

Tier 3, decays quickly: execution cadence. Randomised five to fifteen minute intervals. Jitter across that range overlaps heavily with update checkers, telemetry agents and sync clients. Useful only for narrowing a candidate process already surfaced by tier 1 or 2. Deployed broadly it produces noise at a volume that will discredit the rest of the pack.

Tier 4, near-zero durability: the hashes. Six development builds across a seven-day window, with no confirmed deployment. Published because completeness demands it, and flagged in the first row of the indicator file as nearly useless. **A clean hash sweep is not coverage and must not be reported to stakeholders as coverage.**

A forensic note that belongs with tier 4 rather than the tiers above: the AES-256-GCM key is derived from the current date, so captured ciphertext is very likely recoverable when the send date is known. Preserve historical packet capture before remediating a host.

---

7. What this class makes undetectable

- **The tasking itself.** The decision is requested and returned inside TLS to a commercial provider. Unless you operate the gateway, you can observe that a vote occurred and never learn what it decided.
- **The C2 channel, as a blocking problem.** It is not blockable. Denying `api.deepseek.com` is not a control most organisations can exercise, and the direction of travel is towards permitting more such destinations rather than fewer.
- **Single-provider and on-host variants.** The first removes the quorum; the second removes the network signal entirely. Both are cheap for the author.
- **The content of the exfiltration, in the general case.** Encrypted to a Discord webhook. The date-derived key is a specific weakness of this implementation, not a property of the class.

One asymmetry deserves naming. **The providers are better positioned to detect this than any of their customers are.** DeepSeek, Alibaba, Mistral and Google can observe it from their side, as API traffic whose system prompt announces that the caller is a malware strategist. Talos's report makes no statement about whether any provider was notified or acted, and neither do we. We note only that the best vantage on this technique is one that no defender in this paper's audience occupies, which is the same vantage finding that *Asserted Egress* (concept DOI 10.5281/zenodo.22314504) reached by a different route.

---

8. What actually found it

Not a detection. Not an incident response. Not a victim.

CLOSEDQUORUM was found by CAIRN hunting file metadata at scale, through VirusTotal acquisition channels, on strings that betray AI integration. It was found because someone built a framework to look for a category that did not yet have confirmed victims, and looked anyway.

This is the fifth consecutive paper in this series in which the thing that found the incident was not the defensive stack of anyone it affected. The first three were found by disclosure or by a third party requesting transcripts; the fourth by a volunteer moderator with an edit log; this one by speculative research tooling with no victim in view.

We have stopped treating that as a coincidence and we would encourage readers to do the same. It is worth asking what fraction of your own understanding of this threat class arrived through your controls rather than through someone else's publication.

---

9. Credit

This paper exists because Cisco Talos published a complete technical account, named the mechanism precisely, released the hunting framework under MIT, and stated clearly what they had not established. Ryan Fetterman's reports are the primary source for every fact in section 2, and the open-sourcing of CAIRN is the part with the longest half-life: a taxonomy and a rule corpus that others can extend is worth more than any single family report.

The restraint is worth noting as much as the research. It would have been easy to publish "first autonomous AI malware" without the sentence about unconfirmed deployment. That sentence is there, in the report, unhedged.

---

10. Limitations

- One family, one vendor's analysis, no independent verification.
- No sample obtained. No rule executed against real telemetry from this family.
- The base rate underpinning the primary detection is unmeasured, as stated in 4.1.
- The KQL and SPL in the companion package are written against Defender advanced hunting and Sysmon field names and have not been executed against a live tenant or index. Expect field drift.
- No confirmed in-the-wild deployment, so every operational inference is an inference about a design rather than about observed attacker behaviour.
- ATT&CK mappings are ours, not Talos's: T1102, T1071.001, T1003.001, T1055, T1546.003, T1567.
- We did not examine the CAIRN rule corpus closely enough to assess its false positive profile, and Talos themselves caution that tier 1 and tier 2 hits without genuine AI integration are common.

---

11. What would falsify this

Five conditions, each testable by someone other than us.

1. **A benign base rate high enough to sink rule 1.** If sampling a representative corporate estate shows that a material fraction of ordinary workstations have processes contacting two or more model providers within ten minutes, the quorum signature is not deployable as an alert and section 4 is wrong about its practical value. This is the most likely of the five.
2. **Legitimate concurrent fan-out becoming normal.** If ensembling across providers, rather than failing over between them, becomes a common application pattern, the discriminator collapses. A single popular framework adopting concurrent multi-provider consensus would do it.

3. **A deployed LLM-tasked implant using one provider.** This would confirm the decay argument in section 4.1 ahead of schedule and retire tier 1 and tier 2 immediately.
4. **Sealed-transcript monitors showing the same suppression effect as live ones.** Section 5 claims the distinction is reactivity rather than adversarial origin. If a monitor reading frozen, after-the-fact transcripts is talked down at rates comparable to the live monitor's 1%, the static-versus-live line is wrong and narration is simply unreliable as a class.
5. **CLOSEDQUORUM turning out not to be malware.** If the samples are a researcher's proof of concept or a scam-baiting artifact rather than criminal tooling, the framing throughout is overstated, though the detection logic would survive.

---

12. What we are not claiming

- **Not that anyone was compromised.** No victim is known. This is a capability, not an incident.
- **Not that this is the first AI-integrated malware.** Talos claim, specifically, the first publicly documented Windows implant delegating tactical C2 to a panel of LLMs. That is narrower than the headline the story will acquire, and we adopt their wording rather than a broader one.
- **Not that the providers are culpable.** DeepSeek, Alibaba, Mistral and Google are being used as infrastructure by someone abusing an ordinary commercial API, which has happened to every hosting provider, CDN and paste site before them.
- **Not that the quorum signature is durable.** We argue the opposite, explicitly, in 4.1 and in section 7. It is a detection with an expiry date, offered because now is when it works.
- **Not that our rules are validated.** They are reasoned from a public description and syntactically checked. Nothing more.
- **Not that agentic autonomy in malware is imminent at scale.** One implant with placeholder credentials is not a trend, and we decline to extrapolate a curve from a single point.

---

13. AI disclosure

Written with AI assistance. The synthesis in section 3, the quorum argument in section 4, the static-versus-live narration distinction in section 5, the durability ranking, the falsification conditions and the limitations were authored and reviewed by a human, who is responsible for every claim. The "what we are not claiming" and "what would falsify this" sections exist specifically because AI-assisted analysis tends to overstate both novelty and coverage, and they are written before the conclusions rather than appended to them.

References

Primary

- Fetterman, R., "The Closed Quorum: Inside the first reported autonomous AI C2 implant", Cisco Talos, 22 September 2026.

- Fetterman, R., "Introducing CAIRN: Frontier tracking for AI-integrated malware", Cisco Talos, 22 September 2026.
- Cisco Talos, *Cognitive Artifact Intelligence Research Network*, MIT licence, 22 September 2026. https://github.com/Cisco-Talos/Cognitive-Artifact-Intelligence-Research-Network

Secondary, context only

- Help Net Security, "Researchers uncover malware that uses AI to choose its next move", 22 September 2026.

This series

- *Detection Without Indicators: Agent-Originated Intrusion*, concept DOI 10.5281/zenodo.21770780. Source of the narration correction discussed in section 5, and the paper whose central claim section 3 approaches from the opposite direction.
- *Borrowed Trust*, concept DOI 10.5281/zenodo.21880001.
- *Agentic Intrusion*, concept DOI 10.5281/zenodo.22033405. Source of the provider-egress rule that section 4 explains is insufficient on a workstation.
- *Asserted Egress*, concept DOI 10.5281/zenodo.22314504. Source of the vantage argument referenced in section 7.
- *The Coordination Substrate*, concept DOI 10.5281/zenodo.22678061.

Companion detection content

- saluca-labs/detection-content, `campaigns/2026-09-llm-tasked-c2`, Apache-2.0. https://github.com/saluca-labs/detection-content